# SE-LAB5

Name: Shriram Chandrasekar
SRN: PES2UG24CS495
Section: H

### Objective

Analyse the assigned Python program with three static analysis tools (Pylint, Bandit and Flake8), document the issues found, fix them, and verify the fixes by re-running the tools.

Assigned repo: L5_56_car-rental

Fork (submission): https://github.com/Shriram60/L5_56_car-rental

### 1. Environment Setup

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ python -m venv venv
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ source venv/Scripts/activate
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ pip install pylint bandit flake8
Requirement already satisfied: pygments<3.0.0,>=2.13.0 in c:\users\cshri\se-lab5
nv\lib\site-packages (from rich->bandit) (2.21.0)
Requirement already satisfied: mdurl~=0.1 in c:\users\cshri\se-lab5\l5_56_car-re
ackages (from markdown-it-py>=2.2.0->rich->bandit) (0.1.2)
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ pylint --version
pylint 4.1.3
astroid 4.3.4
Python 3.12.7 (tags/v3.12.7:0b05ead, Oct  1 2024, 03:06:41) [MSC v.1941 64 bit (
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ bandit --version
bandit 1.9.4
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ flake8 --version
7.4.1 (mccabe: 0.7.0, pycodestyle: 2.15.0, pyflakes: 4.0.3) CPython 3.12.7 on Wi

PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$
```

Created a virtual environment and installed Pylint, Bandit and Flake8.

### 2. Run the Program

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ python car_rental.py
Rent Swift: 4500
Rent Swift again: 1500
Rent Innova: -9000
Lookup injection: [('Ravi', 'DL-0420110012345', '9845012345'), ('Meera', 'DL-042
9999')]
Extra km charge: 600
Return unknown car: None
Promo price: 4050.0
Plate valid? True
Licence hash: acb5ec2096ab233046fd883ca20b72a72a1a9354
Admin: True
Available: ['KA01AB1234', 'KA02CD5678', 'KA03EF9999']
Receipt saved to: C:\Users\cshri\AppData\Local\Temp\tmpa51ka89f.txt

PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car rental (main)
```

The program runs. The injection lookup returns every customer row, showing the SQL-injection flaw.

## 3. Before Fixes - Pylint

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ pylint car_rental.py
************* Module car_rental
car_rental.py:33:0: C0301: Line too long (110/100) (line-too-long)
car_rental.py:65:0: C0301: Line too long (123/100) (line-too-long)
car_rental.py:1:0: C0114: Missing module docstring (missing-module-docstring)
car_rental.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:16:0: C0103: Function name "addCar" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:16:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
car_rental.py:16:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inco
car_rental.py:22:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:22:0: C0103: Function name "registerCustomer" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:23:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
car_rental.py:25:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:25:0: C0103: Function name "findCustomer" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:29:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:29:0: C0103: Function name "rentCar" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:36:0: C0103: Function name "returnCar" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:41:4: W0702: No exception type(s) specified (bare-except)
car_rental.py:36:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inco
car_rental.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:44:0: C0103: Function name "bookingCode" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:47:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:47:0: C0103: Function name "licenceHash" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:50:0: C0103: Function name "applyPromo" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:53:4: W0122: Use of exec (exec-used)
car_rental.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:56:0: C0103: Function name "isValidPlate" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:57:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
car_rental.py:57:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return
car_rental.py:62:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:62:0: C0103: Function name "writeReceipt" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:64:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
car_rental.py:65:12: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
car_rental.py:64:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
car_rental.py:70:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:70:0: C0103: Function name "adminLogin" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:75:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:75:0: C0103: Function name "availableCars" doesn't conform to snake_case naming style (invalid-name)
car_rental.py:77:4: C0206: Consider iterating with .items() (consider-using-dict-items)
car_rental.py:78:11: C0121: Comparison 'fleet[p]['available'] == True' should be 'fleet[p]['available'] is True' if checking for
leet[p]['available']' if testing for truthiness (singleton-comparison)
car_rental.py:82:0: C0116: Missing function or method docstring (missing-function-docstring)
car_rental.py:2:0: W0611: Unused import json (unused-import)
```

Pylint findings before fixing.

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ pylint car_rental.py | tail -5
car_rental.py:2:0: W0611: Unused import json (unused-import)

------------------------------------------------------------------
Your code has been rated at 4.94/10 (previous run: 4.94/10, +0.00)


PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
```

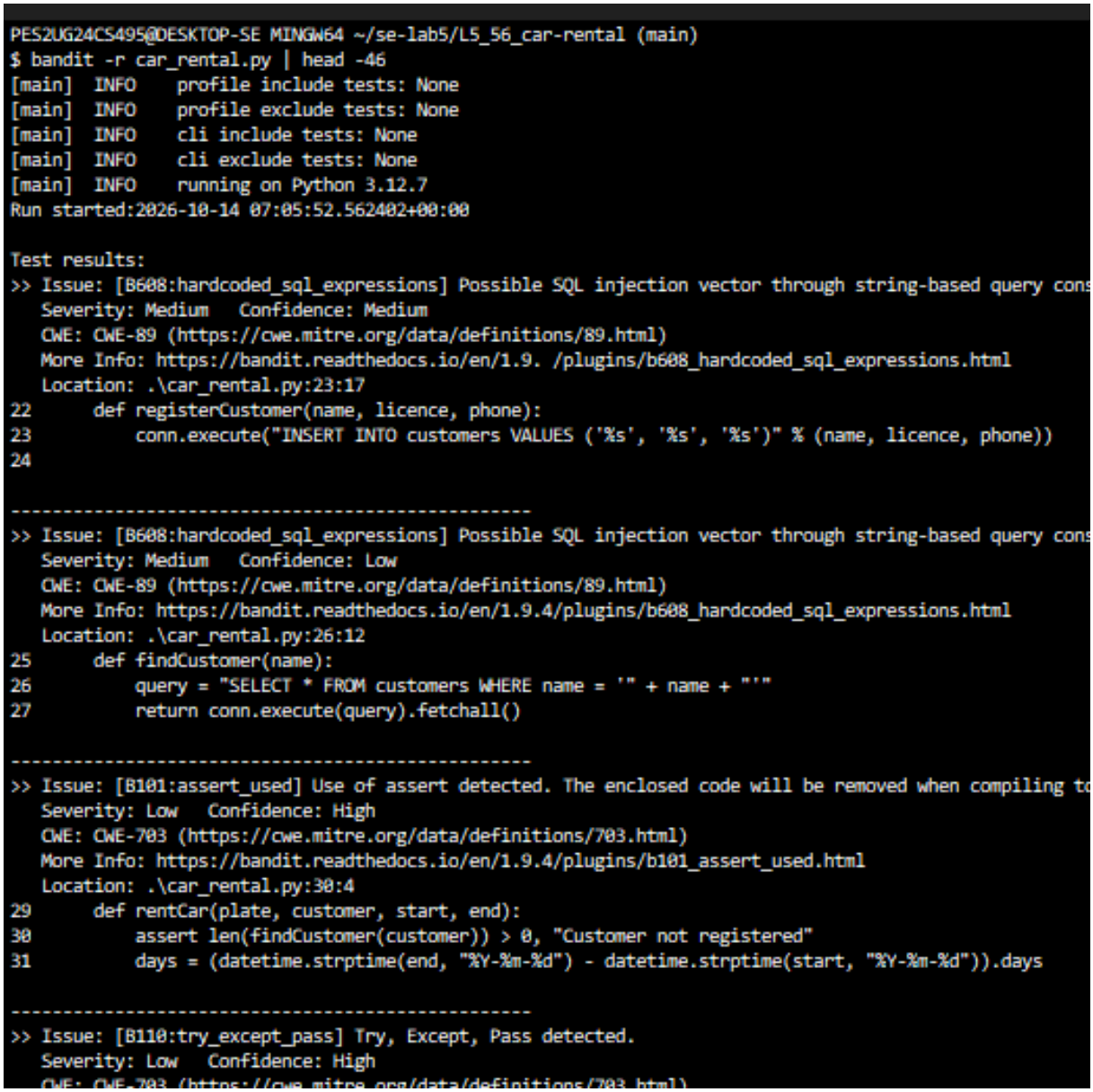
Pylint score before fixing: 4.94/10.

## 4. Before Fixes - Flake8

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ flake8 car_rental.py
car_rental.py:2:1: F401 'json' imported but unused
car_rental.py:16:1: E302 expected 2 blank lines, found 1
car_rental.py:19:80: E501 line too long (96 > 79 characters)
car_rental.py:22:1: E302 expected 2 blank lines, found 1
car_rental.py:23:80: E501 line too long (92 > 79 characters)
car_rental.py:25:1: E302 expected 2 blank lines, found 1
car_rental.py:29:1: E302 expected 2 blank lines, found 1
car_rental.py:31:80: E501 line too long (91 > 79 characters)
car_rental.py:33:80: E501 line too long (110 > 79 characters)
car_rental.py:36:1: E302 expected 2 blank lines, found 1
car_rental.py:41:5: E722 do not use bare 'except'
car_rental.py:44:1: E302 expected 2 blank lines, found 1
car_rental.py:47:1: E302 expected 2 blank lines, found 1
car_rental.py:50:1: E302 expected 2 blank lines, found 1
car_rental.py:56:1: E302 expected 2 blank lines, found 1
car_rental.py:62:1: E302 expected 2 blank lines, found 1
car_rental.py:65:80: E501 line too long (123 > 79 characters)
car_rental.py:70:1: E302 expected 2 blank lines, found 1
car_rental.py:75:1: E302 expected 2 blank lines, found 1
car_rental.py:78:34:  712 comparison to True should be 'if cond is True:' or 'if
car_rental.py:82:1: E302 expected 2 blank lines, found 1
car_rental.py:88:80: E501 line too long (83 > 79 characters)
car_rental.py:89:80: E501 line too long (89 > 79 characters)
car_rental.py:90:80: E501 line too long (84 > 79 characters)
car_rental.py:101:1: E305 expected 2 blank lines after class or function definit
```

Flake8 reports 25 formatting issues.

## 5. Before Fixes - Bandit



```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ bandit -r car_rental.py | head -46
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.7
Run started:2026-10-14 07:05:52.562402+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query cons
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9. /plugins/b608_hardcoded_sql_expressions.html
   Location: .\car_rental.py:23:17
22      def registerCustomer(name, licence, phone):
23          conn.execute("INSERT INTO customers VALUES ('%s', '%s', '%s')" % (name, licence, phone))
24

--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query cons
   Severity: Medium   Confidence: Low
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\car_rental.py:26:12
25      def findCustomer(name):
26          query = "SELECT * FROM customers WHERE name = '" + name + "'"
27          return conn.execute(query).fetchall()

--------------------------------------------------
>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
   Location: .\car_rental.py:30:4
29      def rentCar(plate, customer, start, end):
30          assert len(findCustomer(customer)) > 0, "Customer not registered"
31          days = (datetime.strptime(end, "%Y-%m-%d") - datetime.strptime(start, "%Y-%m-%d")).days

--------------------------------------------------
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
```

Bandit findings (SQL injection, assert, bare except, etc.).

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ bandit -r car_rental.py | tail -38
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b107_hardcoded_password_default.html
   Location: .\car_rental.py:70:0
69
70      def adminLogin(user, password="admin@rent"):
71          if user == "admin" and password == "admin@rent":
72              return True
73          return False
74

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'admin@rent'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\car_rental.py:71:39
70      def adminLogin(user, password="admin@rent"):
71          if user == "admin" and password == "admin@rent":
72              return True

--------------------------------------------------

Code scanned:
        Total lines of code: 84
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 5
                Medium: 4
                High: 2
        Total issues (by confidence):
                Undefined: 0
```

Bandit summary: 11 issues (2 High, 4 Medium, 5 Low).

## 6. Identified Issues

| Issue | Type | Line(s) | Description | Fix Approach |
|---|---|---|---|---|
| SQL injection | Security B608 | 23, 26 | User input put into SQL query | Parameterised ? queries |
| exec() of input | Security B102 | 53 | Promo text run as code | Whitelist of promo codes |
| Weak SHA-1 hash | Security B324 | 48 | Licence hashed with SHA-1 | Use SHA-256 |
| Insecure RNG | Security B311 | 45 | random for booking codes | Use secrets module |
| Temp file + perms | Security B306/B103 | 63, 67 | mktemp race + chmod 0o777 | mkstemp + chmod 0o600 |
| Hardcoded password | Security B105/B107 | 70, 71 | Password in source | Read from environment |
| assert used | Security B101 | 30 | Removed under python -O | Explicit if / raise |
| Bare except | Bug B110 | 41 | Swallows all errors | Explicit membership check |
| Mutable default arg | Bug W0102 | 16 | features=[] shared | Default None |
| Non-snake_case names | Style C0103 | many | addCar, rentCar, ... | Rename to snake_case |
| Missing docstrings | Style C0114/C0116 | all | No documentation | Add docstrings |
| PEP 8 formatting | Style E302/E501 | many | Blank lines, long lines | Fix spacing, wrap lines |

## 7. Fixes - 3 Commits (one per tool)

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ git log --oneline
9a1af2c (HEAD -> main, origin/main, origin/HEAD) Fix Flake8 formatting issues (c
10/10)
79e4c48 Fix Pylint issues (score 4.94 -> 9.75)
e45210d Fix Bandit security issues
3144e3e push lab 5

PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
```

Three commits on the fork, one for each tool's issues.

## 8. After Fixes - Pylint

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ pylint car_rental.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.94/10, +5.06)


PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$
```

Pylint score after fixing: 10.00/10.

## 9. After Fixes - Flake8

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ flake8 car_rental.py

PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$
```

Flake8 reports no issues (empty output).

## 10. After Fixes - Bandit

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ bandit -r car_rental.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.7
Run started:2026-10-14 07:06:43.970085+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 128
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
```

Bandit reports no issues identified.

## 11. Program After Fixes

```
PES2UG24CS495@DESKTOP-SE MINGW64 ~/se-lab5/L5_56_car-rental (main)
$ python car_rental.py
Rent Swift: 4500
Rent Swift again: 1500
Rent Innova: -9000
Lookup injection: []
Extra km charge: 600
Return unknown car: None
Promo price: 4050.0
Plate valid? True
Licence hash: 634fd9c75153e27720c9d70ff84c05972a5f7d575fa39530538cfe7b807a114e
Admin: False
Available: ['KA01AB1234', 'KA02CD5678', 'KA03EF9999']
Receipt saved to: C:\Users\cshri\AppData\Local\Temp\tmp9cs2i0ri.txt

PES2UG24CS495@DESKTOP-SE MINGW64 ~/  -lab5/L5_56_car-rental (main)
$
```

The program still runs; the injection lookup now returns an empty list.